

TASK 02 REPORT

INTERNSHIP
CYBERSECURITY

20
26



WEEK 2 REPORT

Internship Cybersecurity 2026 Project: User Management System Remediation

Submitted By: Muhammad Saim Ali Khan (DHC-4044)

WEEK 2: IMPLEMENTING SECURITY MEASURES

1. REMEDIATION OF IDENTIFIED VULNERABILITIES

Following the Week 1 assessment, the following technical fixes were applied:

- **Input Validation:** Implemented server-side validation to block empty submissions and malformed data, reducing the attack surface for injection exploits.
- **Password Hashing:** Migrated from plain-text storage to **Bcrypt** hashing. This ensures that even in the event of a database breach, user credentials remain computationally infeasible to decrypt.

2. ADVANCED AUTHENTICATION FRAMEWORK

To strengthen the security of administrative functions, the application now utilizes **Token-Based Authentication**:

- **JWT Implementation:** Upon login, the system generates a secure JSON Web Token.
- **Access Control:** Middleware was developed to intercept requests for sensitive actions (Create, View, Update, Delete). Only requests accompanied by a valid, non-expired JWT are permitted to proceed, effectively neutralizing unauthorized access attempts.

3. INFRASTRUCTURE & HEADER HARDENING

To protect data in transit and defend against browser-side exploits, I implemented the **Helmet.js** suite:

- **XSS Protection:** Enforced headers that instruct browsers to stop loading pages when reflected XSS is detected.
- **Clickjacking Prevention:** Set the `X-Frame-Options` to `DENY`, ensuring the application cannot be embedded in malicious iframes.
- **MIME Sniffing:** Disabled the browser's ability to "guess" content types, preventing unauthorized script execution via uploaded files.

SUMMARY OF ACHIEVEMENTS

By the conclusion of Week 2, the application's security posture has been elevated through:

1. **Elimination of SQL Injection** via parameterized queries.
2. **Protection against XSS** through input sanitization and CSP headers.
3. **Secure Credentials** via one-way cryptographic hashing.
4. **Robust Session Management** through stateless JWT authentication.